

VideoFly 网站全量质量检查

阶段总结（累计更新至第 2 阶段）

审计目标	保障网站正常使用；检查前后端一致性、安全、Bug、鉴权与调用链路
当前进度	6 个阶段中已完成 2 个：探索、质量制品生成
当前状态	第 1、2 阶段质量门槛均通过；尚未修改产品源码
下一阶段	第 3 阶段代码审查：逐条验证候选问题并生成回归测试

一、总体结论

阶段性判断：核心鉴权、对象归属、服务端模型校验、回调签名和积分幂等防线基本存在，但支付回跳与长任务恢复链路存在高优先级候选缺陷。

证据强度：目前是审计候选清单，不等同于最终 Bug 数量；第 3、4 阶段会通过代码复核、可执行探针和规格审计确认或排除。

基线结果：原有 149 项测试通过；新增 27 项质量功能测试通过；类型检查、Lint、生产构建和生产依赖审计均已完成。

二、第 1 阶段：全量探索

覆盖范围：鉴权与权限、视频生成、Provider 路由、AI 回调、QStash 对账、积分账本、Stripe、上传与存储、生成器前后端接口。

规模：672 个 Git 跟踪文件，其中 465 个位于 src；采用 200–500 源文件项目的深度范围声明。

探索产出：14 条带文件行号的事实发现、8 个后续候选项、4 个完整模式走查，入口门槛 13/13 通过。

明确不纳入：营销页面视觉、体验优化、非关键文案，以及遗留 Kubernetes/tRPC 模块的深度审计。

第 1 阶段确认的正向防线

- 未登录敏感 API 返回 401，管理员 API 对未授权请求返回 403。
- 管理员权限从数据库实时读取，避免撤权后仍依赖旧 Cookie 缓存。
- 生成入口校验上传图片归属，用户身份由会话得到。
- 前端模型选项与服务器模型能力校验使用共享目录和积分计算逻辑。
- AI 回调具备 HMAC、时间窗口、Provider 与外部任务 ID 绑定。
- 积分冻结、结算和释放具备锁与幂等状态判断。
- 远程媒体已有 HTTPS、私网地址、重定向和字节数限制。

三、当前重点候选问题

级别	问题	正常使用影响	追踪
高	Stripe 回跳不存在的 /dashboard	支付可能成功，但成功、取消或 Billing Portal 返回后出现 404。	REQ-009 / CAND-001
高	长任务超过初始对账窗口后可能悬挂	约 7.5 分钟后 workflow 返回 PENDING；若回调丢失且用户不再轮询，视频与冻结积分可能长期非终态。	REQ-005、REQ-007 / CAND-002
中	Provider 回调枚举遗漏 Bailian	Bailian 已在类型、配置和工厂中定义，但通用回调入口拒绝该标识；当前可能因轮询模式而被掩盖。	REQ-011 / CAND-003
中	AI 回调请求体未显式限流	Stripe Webhook 有 1 MiB 上限，AI 回调直接解析 JSON，形成外部入口防御不一致。	REQ-006、REQ-010 / CAND-004
中	远程媒体 DNS 重绑定窗口	预解析校验与实际 fetch 再次解析之间可能改变目标地址，需要验证部署 HTTP 栈是否已经固定地址。	REQ-010 / CAND-005
中	回调密钥文档变量不一致	部分指南写 AI_CALLBACK_SECRET，代码和示例环境实际要求 CALLBACK_HMAC_SECRET。	REQ-012 / CAND-006
低	CSP 阻止 Vercel 观测脚本	Analytics 和 Speed Insights 在浏览器中被 CSP 拦截，影响事故可观测性，不影响核心生成功能。	CAND-007
覆盖缺口	缺少付费生成完整链路测试	现有测试未在同一确定性流程中覆盖会话、冻结、Provider、存储、结算和账户响应。	CAND-008

四、第 2 阶段：质量制品生成

- 行为契约：**提取并归纳 38 条核心行为契约，覆盖权限、生成输入、积分与视频状态、Provider、回调、媒体安全、Stripe 和部署配置。
- 需求与用例：**形成 12 条可测试需求和 7 个端到端用例；每条需求包含代码证据、适用用例和明确满足条件。

质量场景：形成 10 个面向真实故障后果的适用性场景，包括跨用户媒体、重复支付、慢任务、回调伪造和 DNS 重绑定。

自动检查：新增 27 项 Vitest 功能测试并全部通过；机械枚举脚本可从源码重建 Provider 列表，并稳定检测 Bailian 回调缺口。

后续执行协议：已生成代码审查、集成测试、规格审计和红绿 TDD 四份执行协议，保证后续阶段按同一证据标准进行。

第 2 阶段验证结果

检查	结果	说明
功能测试	通过	27/27
TypeScript	通过	无类型错误
Lint	通过	376 个文件
机械枚举	通过	提取结果可重复；差集为 bailian
制品门槛	通过	10 个核心制品均存在且非空

五、下一阶段计划

第 3 阶段目标：按 12 条需求逐项审查真实代码，使用可执行探针复现候选问题，区分 Bug、设计选择、安全加固和误报。

- 优先确认 Stripe 回跳路由和慢任务积分悬挂两个高优先级候选。
- 机械核对所有 Provider 表示，明确 Bailian 是轮询专用还是回调漏接。
- 为确认的 Bug 生成回归测试补丁，但仍不在审查阶段直接修改产品源码。
- 把无法在本地确认的部署相关问题写明缺失前提，不把“未验证”算作“通过”。

六、审计文件位置

仓库证据： F:\saas411\quality\

核心入口： EXPLORATION.md、 REQUIREMENTS.md、 QUALITY.md、 CONTRACTS.md、
COVERAGE_MATRIX.md、 PROGRESS.md。

本总结： C:\Users\Administrator\Desktop\VideoFly 网站全量质量检查阶段总结.docx